

Beyond STRIDE: References & Further Reading

Participant handout — companion to the talk by Darylynn Ross

This document gives you everything you need to keep going after the talk: the primary source, every case study cited on the slides, the tools mentioned at each MAESTRO layer, and the frameworks worth pairing with MAESTRO.

Links current as of May 2026.

Start Here — The Primary Source

Ken Huang. “Agentic AI Threat Modeling Framework: MAESTRO.” Cloud Security Alliance, February 2025. <https://cloudsecurityalliance.org/blog/2025/02/06/agentic-ai-threat-modeling-framework-maestro>

If you take one thing away from the talk, take this. The paper is free, well-written, and significantly more detailed than the talk could be.

About the author: Ken Huang is CEO and Chief AI Officer of DistributedApps.ai, Co-Chair of the Cloud Security Alliance AI Safety Working Groups, and a contributor to OWASP’s LLM Top 10 and the NIST Generative AI Public Working Group.

The EchoLeak Case Study — Sources by Slide

The deck threads one case study through every layer: **EchoLeak (CVE-2025-32711)**, a zero-click prompt injection in Microsoft 365 Copilot disclosed by Aim Labs in June 2025, CVSS 9.3.

If you want to read the whole story end-to-end, start with Aim Labs’ original disclosure, then the HackTheBox technical breakdown, then the arXiv paper for the academic treatment.

Primary sources (read these in order):

1. **Aim Labs original disclosure** (June 2025) — the canonical first-hand technical writeup. <https://www.aim.security/lp/aim-labs-echoleak-m365>
2. **HackTheBox — “Inside CVE-2025-32711 (EchoLeak): Prompt injection meets AI exfiltration”** — clearest plain-English walkthrough of the attack chain, including the bit cited on slide 6. <https://www.hackthebox.com/blog/cve-2025-32711-echoleak-copilot-vulnerability>

3. **Microsoft Security Response Center — CVE-2025-32711 advisory** — the official vendor record. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-32711>
4. **NIST NVD entry — CVE-2025-32711** — for the official CVSS scoring and CWE classification. <https://nvd.nist.gov/vuln/detail/CVE-2025-32711>
5. **“EchoLeak: The First Real-World Zero-Click Prompt Injection Exploit in a Production LLM System”** (arXiv preprint, September 2025) — academic deep-dive with the full attack chain analysis and proposed defenses. <https://arxiv.org/abs/2509.10540>
6. **Microsoft Security Response Center — “How Microsoft defends against indirect prompt injection attacks”** (July 2025) — Microsoft’s post-incident write-up on their defense strategy. <https://www.microsoft.com/en-us/msrc/blog/2025/07/how-microsoft-defends-against-indirect-prompt-injection-attacks>

Additional analysis (for depth on specific aspects):

- **Checkmarx — “EchoLeak (CVE-2025-32711) shows us that AI security is challenging”** — strong technical analysis of why each Copilot defense failed. <https://checkmarx.com/zero-post/echoleak-cve-2025-32711-show-us-that-ai-security-is-challenging/>
- **Varonis — “EchoLeak in Microsoft Copilot: What it Means for AI Security”** — focuses on the data-access/blast-radius angle. Useful framing for the slide 23 “agent has your privileges” point. <https://www.varonis.com/blog/echoleak>
- **Trend Micro — “Preventing Zero-Click AI Threats: Insights from EchoLeak”** https://www.trendmicro.com/en_us/research/25/g/preventing-zero-click-ai-threats-insights-from-echoleak.html
- **Dark Reading — “Researchers Detail Zero-Click Copilot Exploit ‘EchoLeak’”** — short, news-style summary. <https://www.darkreading.com/application-security/researchers-detail-zero-click-copilot-exploit-echoleak>

MAESTRO — Companion Reading

Ken Huang has published follow-up pieces applying MAESTRO to specific platforms. These are excellent worked examples for anyone trying the framework on a real system.

- **“Threat Modeling OpenAI’s Responses API with the MAESTRO Framework”** (March 2025). <https://cloudsecurityalliance.org/blog/2025/03/24/threat-modeling-openai-s-responses-api-with-the-maestro-framework>

- **“Threat Modeling Google’s A2A Protocol with the MAESTRO Framework”** (April 2025). <https://cloudsecurityalliance.org/blog/2025/04/30/threat-modeling-google-s-a2a-protocol-with-the-maestro-framework>
 - **MAESTRO Threat Analyzer** — official CSA reference tool that walks a system through all seven layers. <https://github.com/CloudSecurityAlliance/MAESTRO>
 - **OWASP MAESTRO Threat Modeling Playbook** — interactive 10-phase threat modeling agent based on OWASP’s Multi-Agentic System Threat Modelling Guide and CSA’s MAESTRO. <https://agentic-threat-modeling.github.io/MAESTRO/>
-

Complementary Frameworks & Standards

The deck argues MAESTRO complements rather than replaces existing frameworks. These are the ones worth knowing.

Threat-modeling frameworks (slide 8, 18)

- **STRIDE** — Microsoft, 1999. The original threat-categorization mnemonic. <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats>
- **PASTA** — Process for Attack Simulation and Threat Analysis. https://owasp.org/www-pdf-archive/AppSecEU2012_PASTA.pdf
- **LINDDUN** — privacy-focused threat modeling. <https://linddun.org>

AI-specific catalogs

- **OWASP Top 10 for LLM Applications** — community catalog of LLM-specific risks. Pairs well with MAESTRO as a threat checklist for L1 and L3. <https://genai.owasp.org>
- **OWASP Multi-Agentic System Threat Modelling Guide v1.0** (April 2025) — extends MAESTRO with explicit multi-agent guidance. <https://genai.owasp.org/resource/multi-agentic-system-threat-modeling-guide-v1-0/>
- **MITRE ATLAS** (cited on slide 42) — Adversarial Threat Landscape for AI Systems. Maps adversarial tactics, techniques, and procedures against AI. Aligns reasonably well to MAESTRO layers. <https://atlas.mitre.org>

Regulation & standards (cited on slide 42)

- **NIST AI Risk Management Framework (AI RMF 1.0)** — useful when you need a regulatory hook to fund AI security work. <https://www.nist.gov/itl/ai-risk-management-framework>
- **NIST AI 600-1 — Generative AI Profile** (July 2024 companion document). <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

- **ISO/IEC 42001:2023** — international management system standard for AI. Auditors are starting to ask. <https://www.iso.org/standard/81230.html>
 - **EU AI Act (Regulation 2024/1689)** — entered into force August 2024; phased applicability through 2027. <https://artificialintelligenceact.eu>
 - **NIST AI 100-2 E2025 — “Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations”** (March 2025). <https://csrc.nist.gov/pubs/ai/100/2/e2025/final>
-

Foundational Papers — If You Want to Go Deeper

These are the canonical academic papers behind the threats discussed in the talk.

- **Greshake et al. “Not what you’ve signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection.”** AISC ‘23. The paper that named indirect prompt injection and is foundational to understanding EchoLeak and every attack in the deck. <https://arxiv.org/abs/2302.12173>
 - **Carlini et al. “Extracting Training Data from Large Language Models.”** USENIX Security 2021. The data-extraction work that motivates the L1 threats on slide 32. <https://arxiv.org/abs/2012.07805>
 - **Debenedetti et al. “Defeating Prompt Injections by Design.”** arXiv preprint, March 2025 (revised June 2025). Google, Google DeepMind, and ETH Zurich researchers propose CaMeL (CAPabilities for MachinE Learning), a defense that wraps the LLM in a protective system layer rather than trying to make the model itself injection-resistant. It extracts control and data flow from the trusted user query, then uses a custom Python interpreter and capability metadata to enforce security policies on every tool call — so untrusted data retrieved by the agent can never influence which tools run or where data is exfiltrated. Inspired by Control Flow Integrity, Access Control, and Information Flow Control. Solves 77% of AgentDojo tasks with provable security. Relevant across MAESTRO L3 (agent frameworks) and L4 (deployment) as a concrete design pattern for the “agent has your privileges” problem raised on slide 23. <https://arxiv.org/abs/2503.18813>
 - **CaMeL reference implementation** — Google Research’s open-source release accompanying the paper, including the custom interpreter and AgentDojo integration. Worth reading alongside the paper to see how capabilities are tracked in practice. <https://github.com/google-research/camel-prompt-injection>
 - **Simon Willison’s prompt-injection archive** — the most comprehensive ongoing chronicle of prompt injection in the wild. Subscribe to his blog if you want one feed for staying current. <https://simonwillison.net/tags/prompt-injection/>
-

Stay In Touch

Darylynn Ross Sr. Application Security Engineer, Product Security CoverMyMeds, part of McKesson Corporation

If you'd like the slides, the speaker script, or have follow-up questions, reach out. This handout will be kept up to date as the EchoLeak research evolves and as MAESTRO follow-up papers ship — check back for revisions.

Disclaimer: I do a ton of threat modeling, but I am not an expert on MAESTRO. I am presenting because I'm learning this myself and want to share it. Suggestions, corrections, and "have you read..." notes are welcome.